🔎 Fase 2: Fingerprinting: Subdominios y Tecnologías

🌐 Análisis de Subdominios e Identificación de Tecnologías (Gowitness)

Con el objetivo de analizar los servicios web detectados en los subdominios activos e identificar las tecnologías utilizadas por cada host, se utilizó la herramienta **Gowitness** durante la fase de **Fingerprinting**.

Este análisis permitió recorrer automáticamente los subdominios descubiertos previamente, registrar información relevante sobre cada servicio web y centralizar los resultados en una interfaz que facilita el análisis de los hosts detectados.

🛠️ Herramienta utilizada

```
gowitness
```

Gowitness es una herramienta utilizada en procesos de reconocimiento web que permite visitar automáticamente múltiples hosts, recopilar información de los servicios web accesibles y almacenar los resultados en una base de datos que posteriormente puede visualizarse mediante una interfaz web local.

💻 Comandos ejecutados

Primero se ejecutó el escaneo utilizando como entrada el archivo que contiene los subdominios activos identificados previamente:

```
┌──(kali㉿kali)-[~/…/Fingerprinting/dominios_txt/dominios_vivos_finales/gowitness]
└─$ sudo gowitness scan file -f subdominios_vivos_ok.txt --write-db
2026/03/08 13:27:39 INFO result 🤖 target=http://ads-events.mercadolibre.com:443 status-code=403 title="403 Forbidden" have-sc
reenshot=true
2026/03/08 13:27:39 INFO result 🤖 target=https://api.mercadolibre.com:443 status-code=404 title="" have-screenshot=true
2026/03/08 13:27:39 INFO result 🤖 target=http://ads-events.mercadolibre.com:80 status-code=403 title="403 Forbidden" have-scr
eenshot=true
2026/03/08 13:27:39 INFO result 🤖 target=http://api.mercadolibre.com:443 status-code=404 title="" have-screenshot=true
2026/03/08 13:27:39 INFO result 🤖 target=http://api.mercadolibre.com:80 status-code=404 title="" have-screenshot=true
2026/03/08 13:27:39 INFO result 🤖 target=https://ads-events.mercadolibre.com:443 status-code=403 title="403 Forbidden" have-s
creenshot=true
```

```
sudo gowitness scan file -f subdominios_vivos_ok.txt --write-db
```

Este comando permitió que la herramienta visitara automáticamente cada uno de los subdominios activos, registrando información como:

- código de estado HTTP
- título de la página
- información de navegación y registros asociados

Toda la información recopilada fue almacenada en una base de datos generada por la herramienta.

Una vez finalizado el proceso de escaneo, se inició el servidor web integrado de Gowitness para analizar los resultados obtenidos:

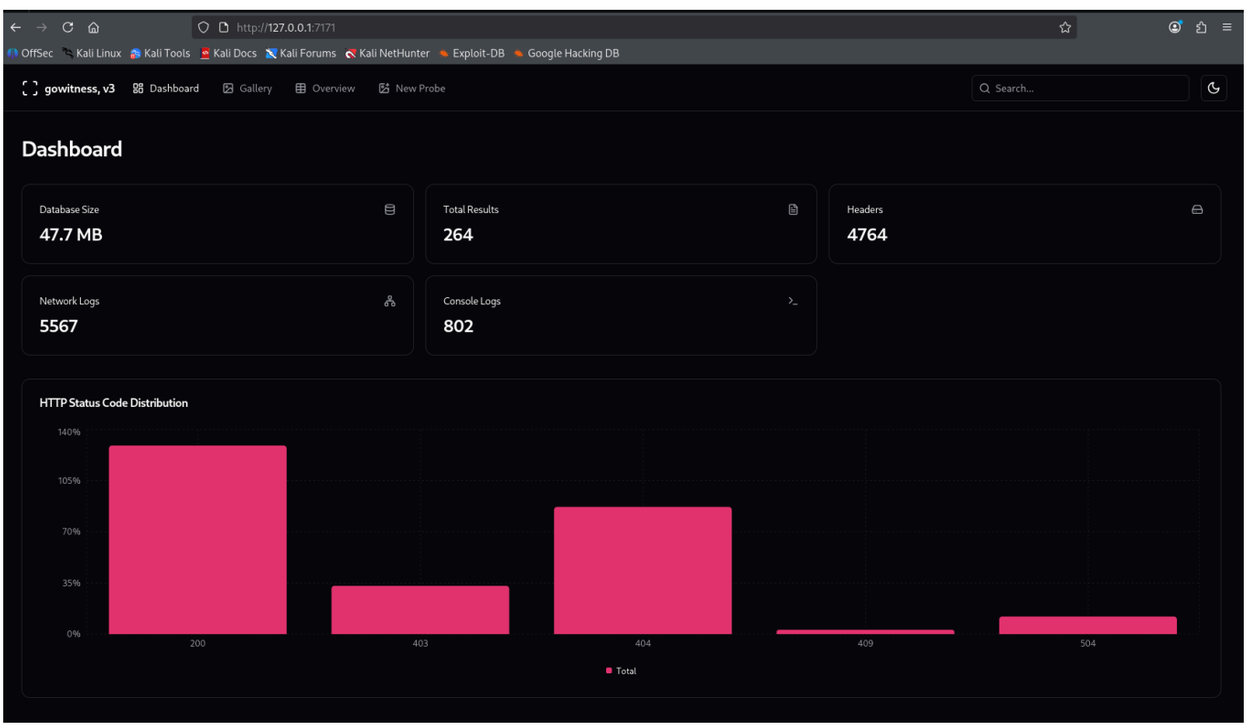
```
┌──(kali㉿kali)-[~/…/Fingerprinting/dominios_txt/dominios_vivos_finales/gowitness]
└─$ sudo gowitness report server
2026/03/08 13:38:22 INFO starting web server host=127.0.0.1 port=7171
2026/03/08 13:39:43 "GET http://127.0.0.1:7171/ HTTP/1.1" from 127.0.0.1:51342 - 200 481B in 8.121098ms
2026/03/08 13:39:43 "GET http://127.0.0.1:7171/assets/index-CLzylN3h.css HTTP/1.1" from 127.0.0.1:51358 - 200 42974B in 450.53
4µs
2026/03/08 13:39:43 "GET http://127.0.0.1:7171/assets/index-Dy9LEUPM.js HTTP/1.1" from 127.0.0.1:51342 - 200 895660B in 1.8187
24ms
2026/03/08 13:39:43 "GET http://127.0.0.1:7171/favico.ico HTTP/1.1" from 127.0.0.1:51342 - 200 1150B in 137.302µs
2026/03/08 13:39:44 "GET http://127.0.0.1:7171/api/statistics HTTP/1.1" from 127.0.0.1:51358 - 200 229B in 211.977119ms
```

```
sudo gowitness report server
```

Esto permitió levantar una interfaz web local accesible desde el navegador en:

```
http://127.0.0.1:7171
```

Desde esta interfaz fue posible revisar el dashboard de resultados, incluyendo estadísticas generales del escaneo, distribución de códigos HTTP y la información recopilada para cada subdominio.



📊 Tecnologías y patrones observados

El análisis de los subdominios activos permitió identificar ciertos patrones tecnológicos e infraestructurales compartidos entre múltiples hosts.

En primer lugar, se observó una fuerte homogeneidad en la infraestructura utilizada. La mayoría de los subdominios se encontraban desplegados sobre **Amazon Web Services (AWS)** y utilizando **Amazon CloudFront** como capa de distribución de contenido. En varios casos también se identificó **Tengine**, una variante optimizada de **Nginx**, funcionando como servidor web frontend.

Este patrón sugiere una arquitectura basada en:

```
AWS → CloudFront → Tengine/Nginx
```

Muchos de los subdominios detectados respondían con códigos **HTTP 403** o **HTTP 404**, lo que indica que los hosts existen dentro de la infraestructura pero que las rutas públicas se encuentran restringidas o no expuestas. Este comportamiento suele observarse en arquitecturas donde múltiples servicios comparten una misma capa de distribución o gateway.

Por otro lado, los subdominios que respondían con **HTTP 200** correspondían a servicios activos o aplicaciones funcionales. En estos casos se observó el uso de **HTTPS con TLS 1.2 / TLS 1.3**, certificados emitidos por **Amazon RSA 2048** y políticas de seguridad como **HSTS**. También se identificaron tecnologías como **Ruby on Rails** en el backend y recursos cargados desde CDNs externas.

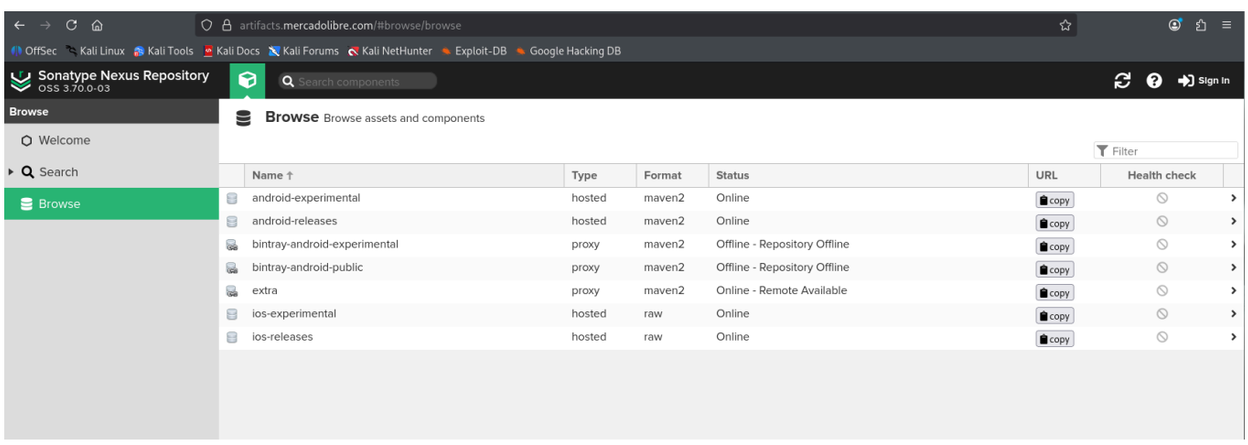
Durante el análisis también se detectaron algunos servicios de autenticación centralizada, incluyendo portales de login asociados a **Okta**, lo que sugiere el uso de mecanismos de **Single Sign-On (SSO)** dentro de la infraestructura.

Asimismo, se identificaron algunos endpoints que respondían con salidas mínimas o estructuradas (por ejemplo respuestas **JSON**), lo que indica la posible existencia de **APIs o servicios backend internos** expuestos a través de la misma infraestructura de distribución.

📦 Hallazgo relevante: repositorio Nexus expuesto

Durante la exploración de subdominios se identificó el host:

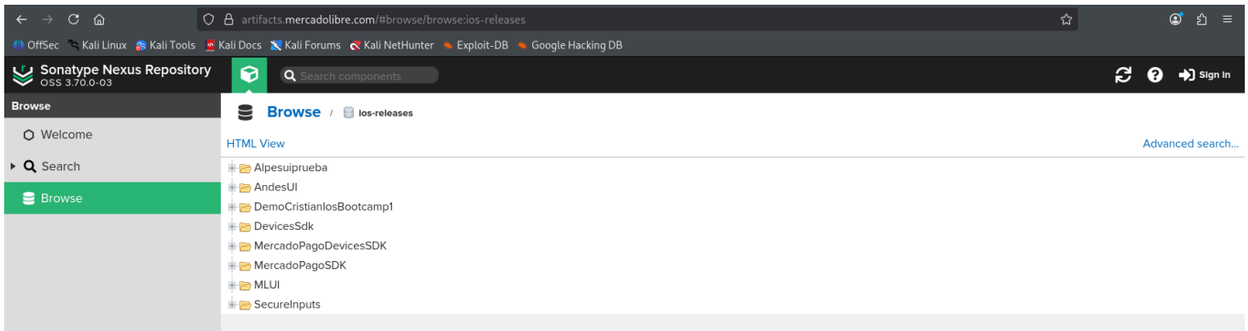
```
artifacts.mercadolibre.com
```



Este subdominio exponía una instancia pública de **Sonatype Nexus Repository OSS (v3.70.0-03)**, utilizada como gestor de artefactos dentro de pipelines de desarrollo.

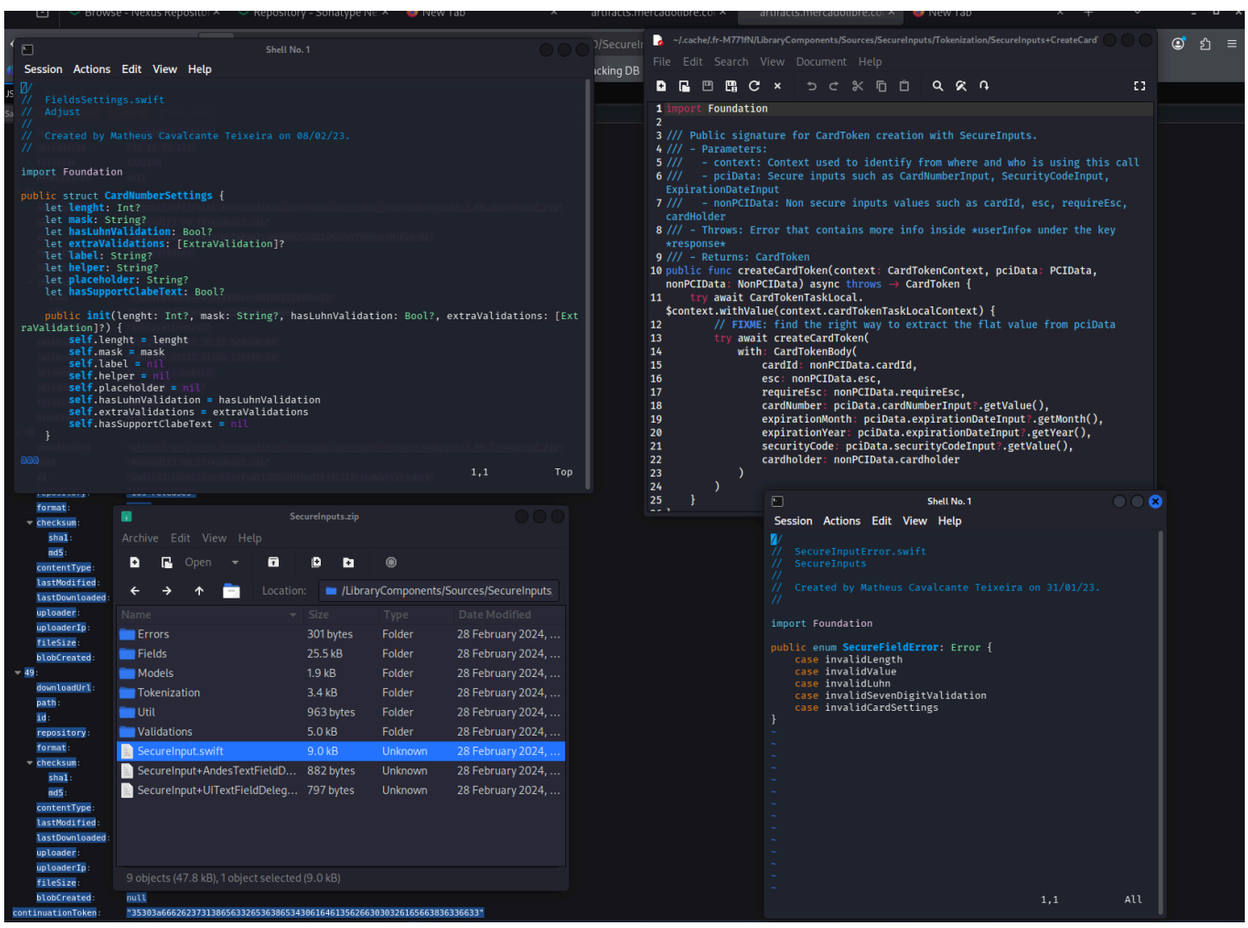
A través de la interfaz web fue posible observar múltiples repositorios destinados a la distribución de dependencias internas, incluyendo repositorios asociados a aplicaciones móviles como:

- `android-releases`
- `android-experimental`
- `ios-releases`
- `ios-experimental`

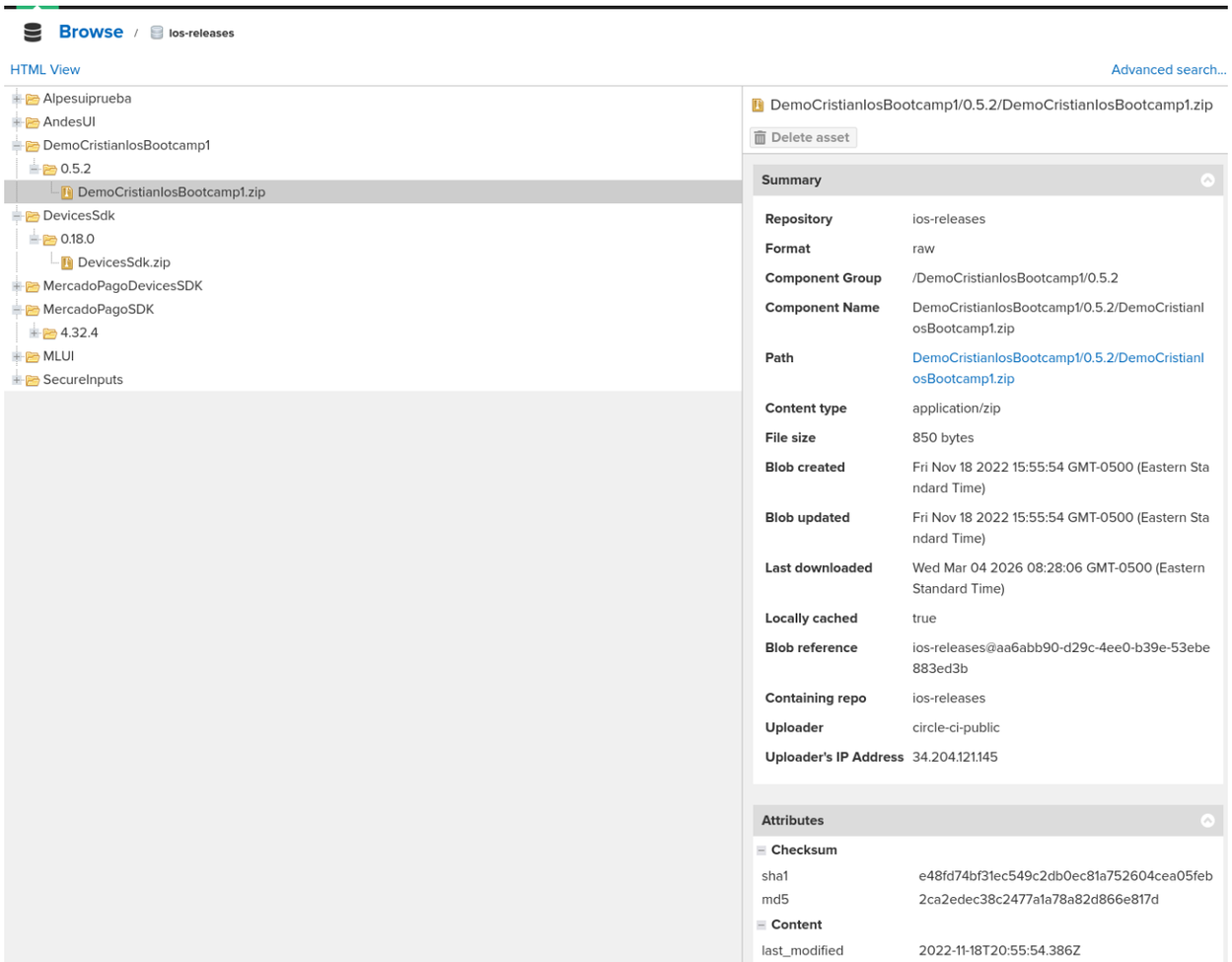


Estos repositorios contenían diferentes paquetes organizados en estructuras típicas de **Maven** y repositorios **raw**, lo que indica que el servicio funciona como un **almacén central de dependencias y componentes internos** dentro del ecosistema de desarrollo.

Dentro del repositorio `ios-releases` se identificaron diversos artefactos asociados a proyectos internos, incluyendo librerías relacionadas con **MercadoPago**, SDKs de dispositivos y otros módulos utilizados por aplicaciones móviles. Algunos de estos artefactos podían descargarse directamente desde la interfaz, revelando fragmentos de implementación relacionados con el manejo de **datos sensibles de tarjetas** y la generación de **CardToken**.



Adicionalmente, los metadatos del repositorio mostraban referencias a procesos de integración continua como **circle-ci-public**, lo que sugiere que este servicio forma parte de la infraestructura de **DevOps y distribución de librerías internas** utilizada por la organización.



La exposición pública de este tipo de repositorios puede revelar información relevante sobre la arquitectura interna de desarrollo, incluyendo nombres de proyectos, dependencias utilizadas por aplicaciones móviles y componentes relacionados con el procesamiento seguro de pagos dentro del ecosistema de la plataforma.

📄 Conclusión

El uso de **Gowitness** permitió realizar un análisis detallado de los subdominios activos identificados durante la fase de **Fingerprinting**, facilitando la identificación de tecnologías utilizadas, patrones de infraestructura y servicios relevantes dentro del entorno analizado.

Si bien la mayoría de los subdominios pertenecían a una infraestructura compartida basada en **AWS, CloudFront y Tengine**, el análisis permitió identificar algunos servicios específicos que revelan componentes internos del ecosistema tecnológico, entre ellos el repositorio de artefactos **Nexus**, el cual expone información significativa sobre la estructura de desarrollo y distribución de dependencias utilizada por la organización.